08 / SLIDE 001 Autenticazione e autorizzazione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 1 di 14

Spiegazione per studiare

La lezione affronta la protezione delle risorse Web e distingue l'identificazione di chi accede dal controllo di ciò che può fare. Si studiano credenziali, più fattori, token, autenticazione federata e modelli di autorizzazione.

Definizioni, passaggi ed esempi presenti nella slide

Autenticazione e Autorizzazione

SLIDE ORIGINALE · diagrammi, tabelle e codice





Autenticazione e Autorizzazione

08 / SLIDE 002 Introduzione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 2 di 14

Spiegazione per studiare

Autenticazione e autorizzazione risolvono problemi diversi. La prima verifica l'identità del richiedente; la seconda decide se quella identità può compiere una certa operazione su una risorsa. Entrambi i controlli sono necessari per proteggere dati riservati.

Definizioni, passaggi ed esempi presenti nella slide

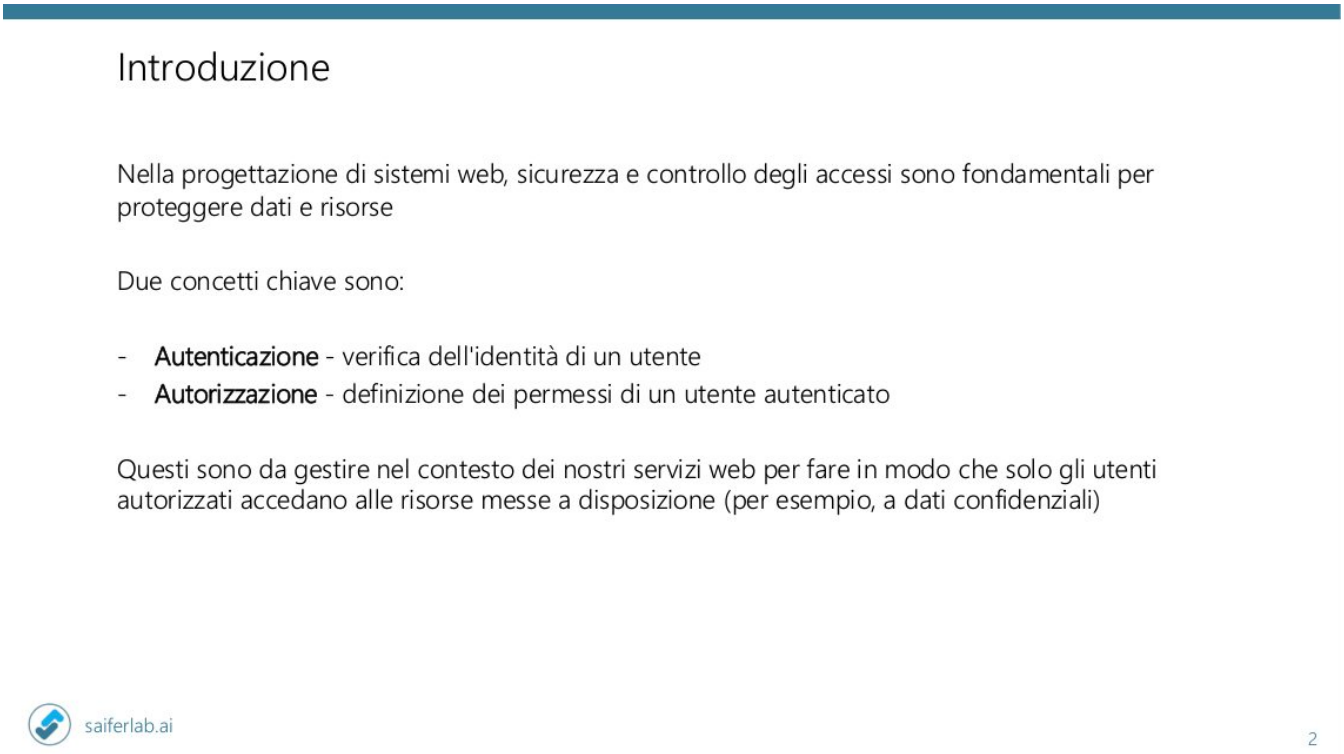
Nella progettazione di sistemi web, sicurezza e controllo degli accessi sono fondamentali per proteggere dati e risorse

Due concetti chiave sono:

- Autenticazione - verifica dell'identità di un utente
- Autorizzazione - definizione dei permessi di un utente autenticato

Questi sono da gestire nel contesto dei nostri servizi web per fare in modo che solo gli utenti autorizzati accedano alle risorse messe a disposizione (per esempio, a dati confidenziali)

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 003 Autenticazione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 3 di 14

Spiegazione per studiare

Le tecniche di autenticazione citate includono username/password, fattori multipli, token di sessione o JWT e servizi esterni mediante OAuth/OpenID Connect. Il sistema deve scegliere un meccanismo adatto al contesto e applicarlo alle richieste che necessitano di identità verificata.

Definizioni, passaggi ed esempi presenti nella slide

L'autenticazione assicura che chi accede a un sistema sia chi dichiara di essere. Può avvenire con diversi metodi:

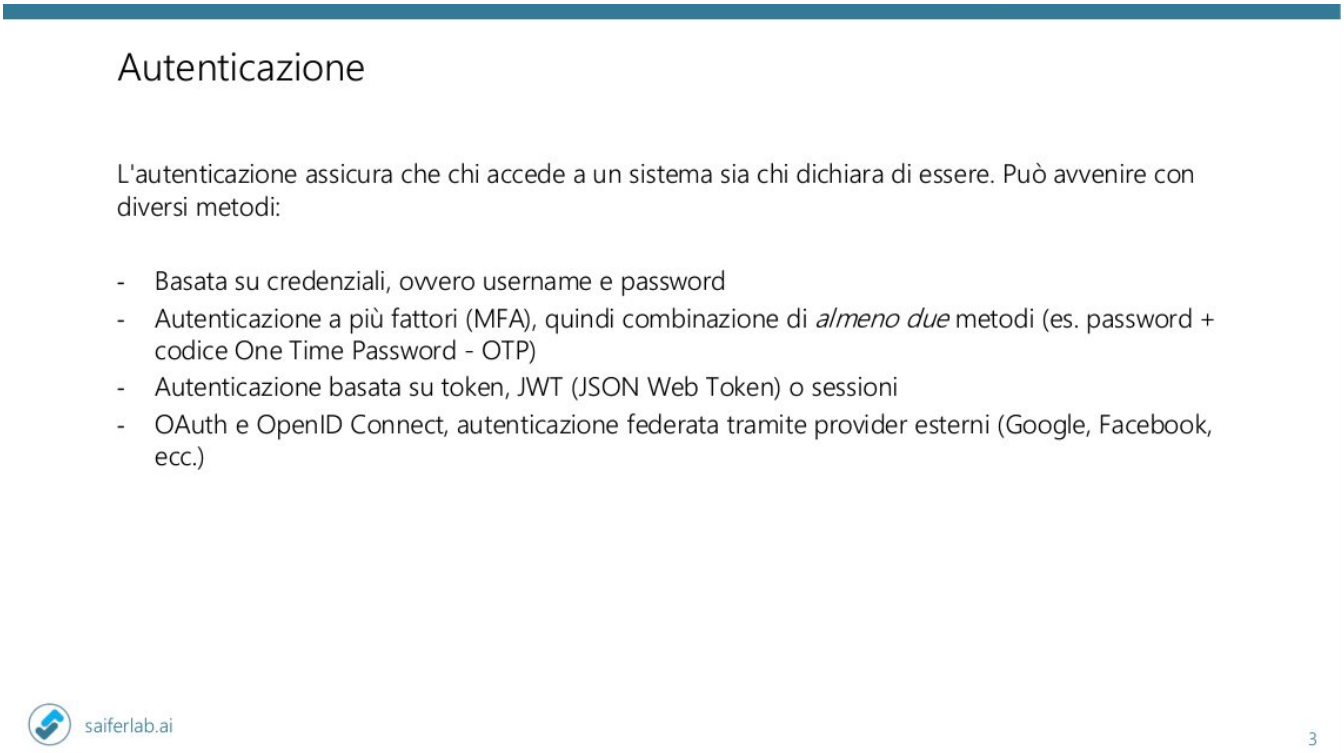
• Basata su credenziali, ovvero username e password

• Autenticazione a più fattori (MFA), quindi combinazione di almeno due metodi (es. password + codice One Time Password - OTP)

• Autenticazione basata su token, JWT (JSON Web Token) o sessioni

• OAuth e OpenID Connect, autenticazione federata tramite provider esterni (Google, Facebook, ecc.)

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 004 Flusso tipico dell’autenticazione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 4 di 14

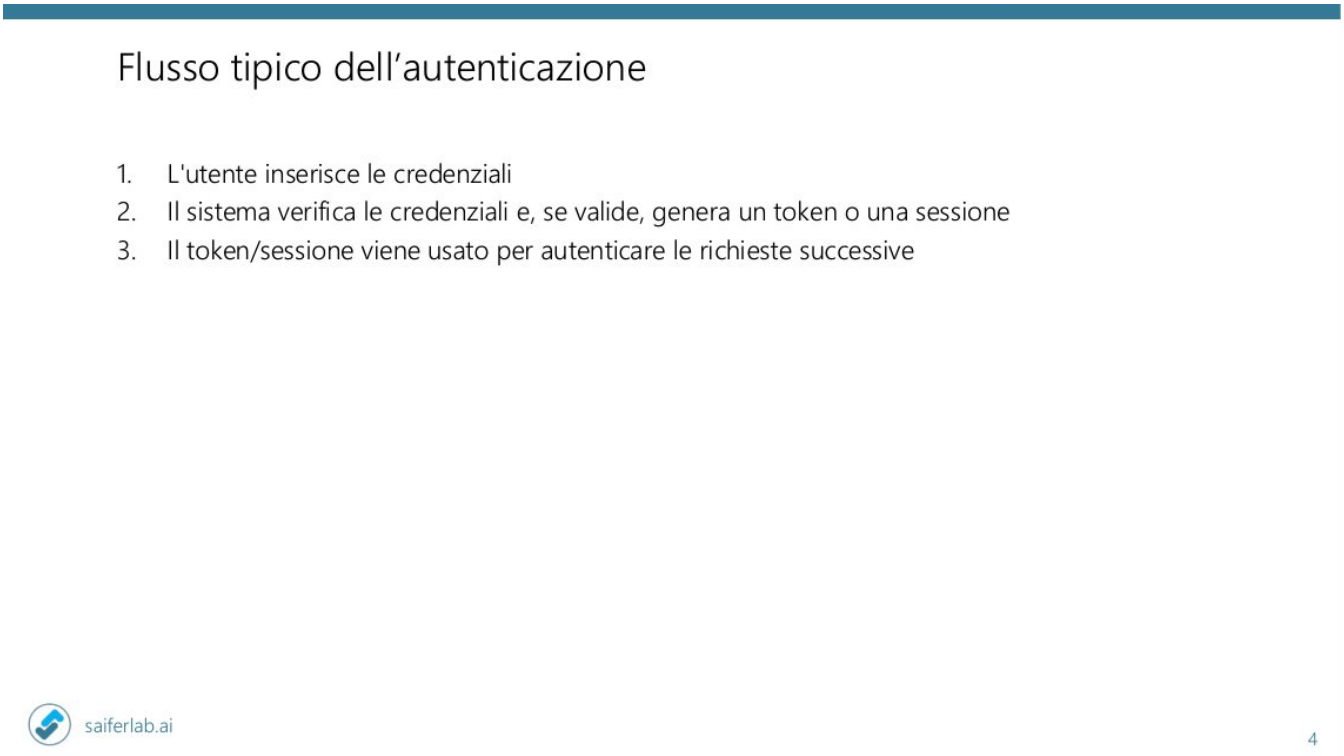
Spiegazione per studiare

Nel flusso tipico l'utente invia le credenziali, il server le verifica e crea una sessione o rilascia un token. Nelle richieste successive tale informazione consente di riconoscere l'utente senza ripetere ogni volta l'intera procedura di login.

Definizioni, passaggi ed esempi presenti nella slide

1. L'utente inserisce le credenziali 2. Il sistema verifica le credenziali e, se valide, genera un token o una sessione 3. Il token/sessione viene usato per autenticare le richieste successive

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 005 Autenticazione basata su credenziali

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 5 di 14

Spiegazione per studiare

Le credenziali sono semplici da usare ma vulnerabili, per esempio, a tentativi ripetuti e phishing. Le dispense raccomandano protezione delle password mediante hashing e politiche di sicurezza appropriate. È importante che le credenziali non vengano conservate indiscriminatamente in chiaro.

Definizioni, passaggi ed esempi presenti nella slide

Username e password sono il metodo più comune, ma soggetto a vulnerabilità come attacchi brute-force e phishing

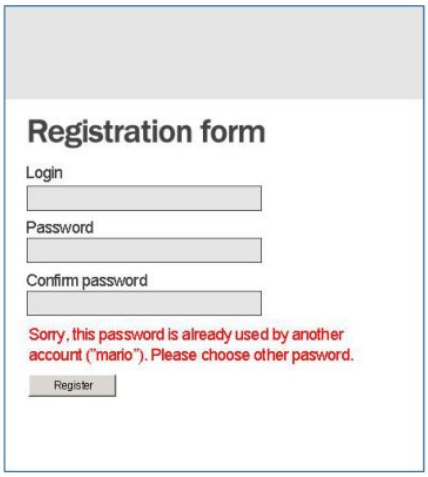
Best practice: uso di hashing con algoritmi sicuri per la cifratura, l'archiviazione e la verifica e obbligo di password complesse richieste agli utenti

SLIDE ORIGINALE · diagrammi, tabelle e codice

Autenticazione basata su credenziali

Username e password sono il metodo più comune, ma soggetto a vulnerabilità come attacchi brute-force e phishing

Best practice: uso di **hashing** con algoritmi sicuri per la cifratura, l'archiviazione e la verifica e obbligo di password complesse richieste agli utenti



saiferlab.ai

5

08 / SLIDE 006 Multi Factor Authentication (MFA)

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 6 di 14

Spiegazione per studiare

L'autenticazione multifattore combina prove differenti: qualcosa che si conosce, qualcosa che si possiede e/o una caratteristica biometrica. Un secondo fattore riduce l'effetto della compromissione della password, perché è necessaria un'ulteriore prova di identità.

Definizioni, passaggi ed esempi presenti nella slide

Per essere autenticato, l’utente può superare diverse prove (due per la two-factor authentication, 2FA). L’idea è che solo se l’utente è chi dice di essere può superare i vari livelli di autenticazione

Si scelgono due o più metodi distinti (possibilmente di tipo diverso) tra:

- Qualcosa che l’utente sa (password, PIN)
- Qualcosa che l’utente ha (OTP via SMS, email o app come Google Authenticator)
- Qualcosa che l’utente è (biometria: impronte digitali, riconoscimento facciale)

Vantaggi: aumenta la sicurezza riducendo il rischio di accessi non autorizzati anche in caso di credenziali compromesse

SLIDE ORIGINALE · diagrammi, tabelle e codice

Multi Factor Authentication (MFA)

Per essere autenticato, l’utente può superare diverse prove (due per la two-factor authentication, 2FA). L’idea è che solo se l’utente è chi dice di essere può superare i vari livelli di autenticazione

Si scelgono due o più metodi distinti (possibilmente di tipo diverso) tra:

- Qualcosa che l’utente sa (password, PIN)
- Qualcosa che l’utente ha (OTP via SMS, email o app come Google Authenticator)
- Qualcosa che l’utente è (biometria: impronte digitali, riconoscimento facciale)

Vantaggi: aumenta la sicurezza riducendo il rischio di accessi non autorizzati anche in caso di credenziali compromesse



saiferlab.ai

6

08 / SLIDE 007 Autorizzazione basata su token

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 7 di 14

Spiegazione per studiare

Dopo l'autenticazione, il client può usare un token per accompagnare le richieste. La slide distingue session token e JWT, sottolineando anche i rischi di memorizzazione insicura nel browser. Il token deve essere gestito come informazione sensibile e può avere una scadenza.

Definizioni, passaggi ed esempi presenti nella slide

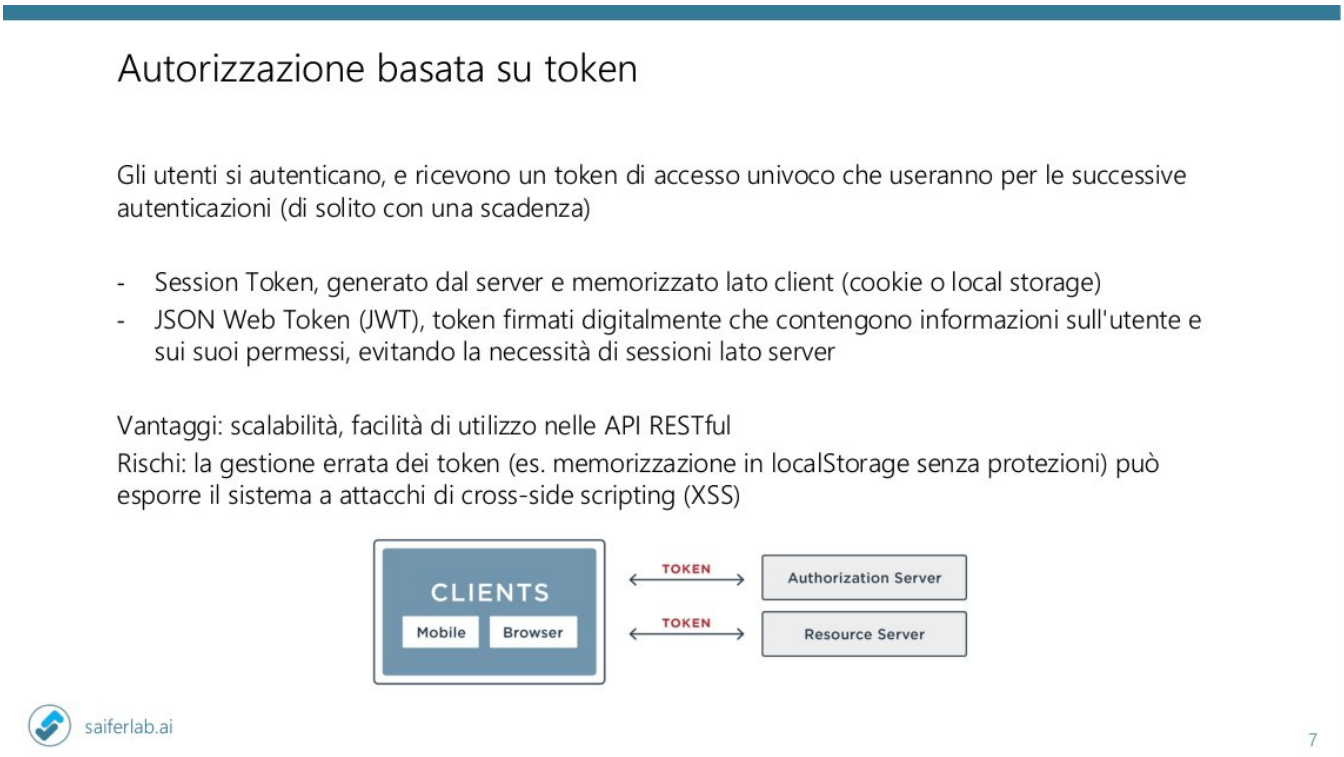
Gli utenti si autenticano, e ricevono un token di accesso univoco che useranno per le successive autenticazioni (di solito con una scadenza)

• Session Token, generato dal server e memorizzato lato client (cookie o local storage)

• JSON Web Token (JWT), token firmati digitalmente che contengono informazioni sull'utente e sui suoi permessi, evitando la necessità di sessioni lato server

Vantaggi: scalabilità, facilità di utilizzo nelle API RESTful Rischi: la gestione errata dei token (es. memorizzazione in localStorage senza protezioni) può esporre il sistema a attacchi di cross-side scripting (XSS)

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 008 Autenticazione federata

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 8 di 14

Spiegazione per studiare

L'autenticazione federata permette di usare un identity provider esterno e si collega al Single Sign-On. Riduce il numero di credenziali direttamente gestite dai singoli servizi, ma lega una parte importante della sicurezza all'account presso il provider.

Definizioni, passaggi ed esempi presenti nella slide

OAuth 2.0 e OpenID Connect: permettono agli utenti di autenticarsi tramite provider esterni come Google, Facebook, Microsoft SSO (Single Sign-On): un'unica autenticazione permette l'accesso a più servizi senza dover reinserire le credenziali

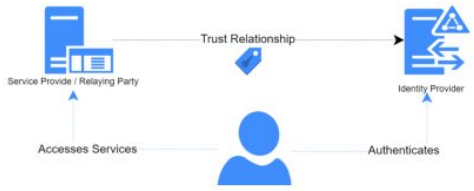
Vantaggi: riduzione del numero di password da gestire, maggiore sicurezza e praticità Rischi: se l'account del provider viene compromesso, tutti i servizi collegati sono a rischio

SLIDE ORIGINALE · diagrammi, tabelle e codice

Autenticazione federata

OAuth 2.0 e OpenID Connect: permettono agli utenti di autenticarsi tramite **provider** esterni come Google, Facebook, Microsoft
SSO (Single Sign-On): un'unica autenticazione permette l'accesso a più servizi senza dover reinserire le credenziali

Vantaggi: riduzione del numero di password da gestire, maggiore sicurezza e praticità
Rischi: se l'account del provider viene compromesso, tutti i servizi collegati sono a rischio



saiferlab.ai

8

08 / SLIDE 009 Autorizzazione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 9 di 14

Spiegazione per studiare

L'autorizzazione stabilisce i permessi dopo che l'utente è stato riconosciuto. La slide distingue RBAC, basato sui ruoli, ABAC, basato su attributi del contesto e dell'utente, e ACL, che associa permessi a specifiche risorse.

Definizioni, passaggi ed esempi presenti nella slide

L'autorizzazione determina quali azioni un utente autenticato può eseguire

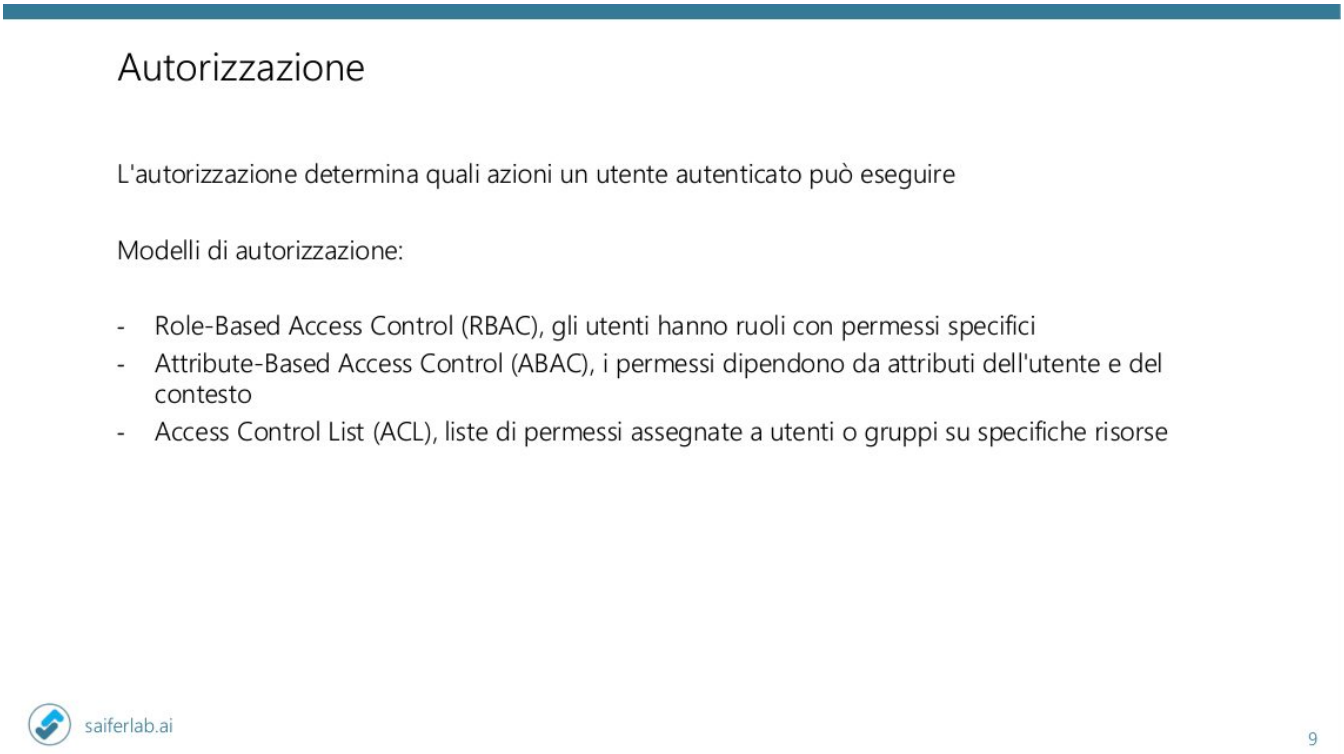
Modelli di autorizzazione:

• Role-Based Access Control (RBAC), gli utenti hanno ruoli con permessi specifici

• Attribute-Based Access Control (ABAC), i permessi dipendono da attributi dell'utente e del contesto

• Access Control List (ACL), liste di permessi assegnate a utenti o gruppi su specifiche risorse

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 010 Esempio di flusso di autorizzazione

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 10 di 14

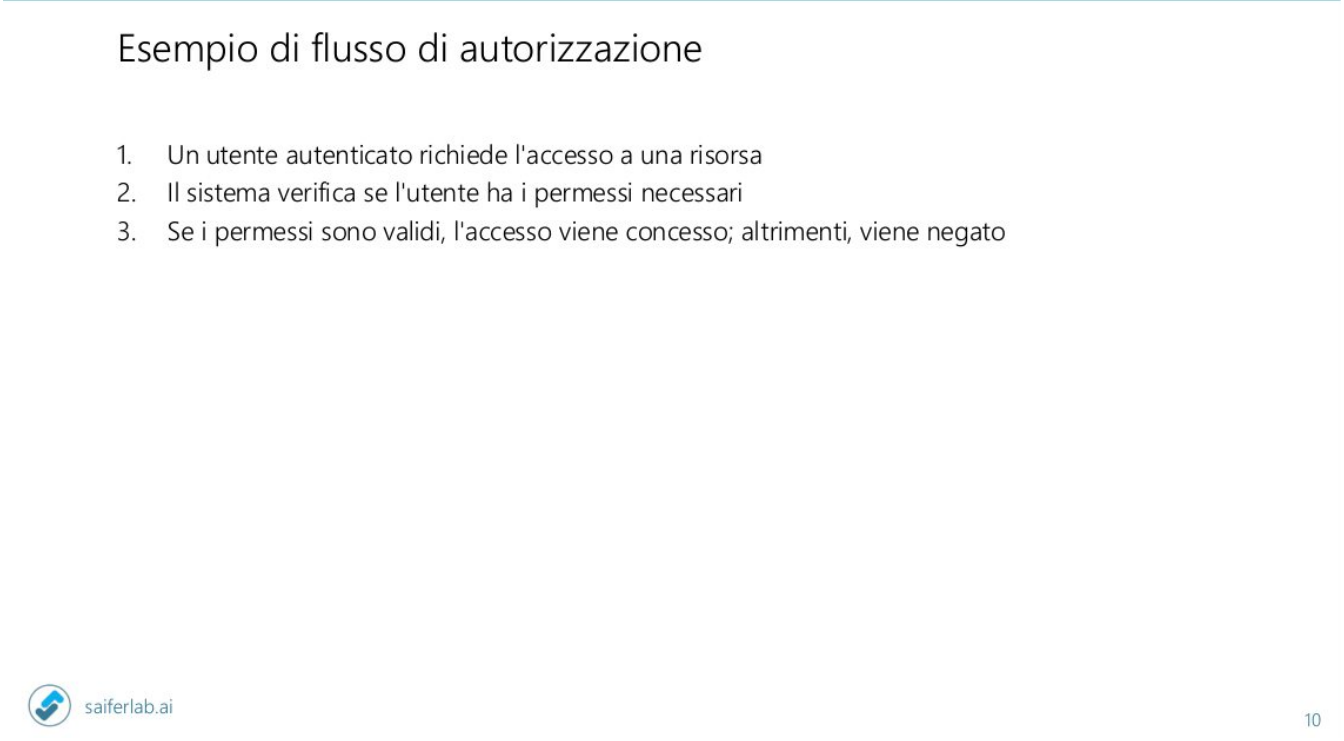
Spiegazione per studiare

Il ciclo di autorizzazione comincia con una richiesta di accesso, continua con la verifica dei permessi e termina con un esito di concessione o rifiuto. Anche un utente autenticato può ricevere un diniego se l'operazione non rientra nei suoi privilegi.

Definizioni, passaggi ed esempi presenti nella slide

1. Un utente autenticato richiede l'accesso a una risorsa 2. Il sistema verifica se l'utente ha i permessi necessari 3. Se i permessi sono validi, l'accesso viene concesso; altrimenti, viene negato

SLIDE ORIGINALE · diagrammi, tabelle e codice



08 / SLIDE 011 Role-Based Access Control (RBAC)

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 11 di 14

Spiegazione per studiare

RBAC assegna utenti a ruoli, come amministratore o utente ordinario, e collega i permessi a tali ruoli. È comodo quando molti utenti condividono le stesse autorizzazioni, ma può essere meno flessibile per eccezioni temporanee o individuali.

Definizioni, passaggi ed esempi presenti nella slide

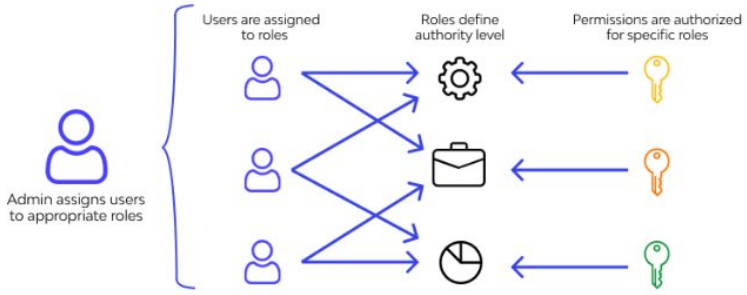
Gli utenti sono assegnati a ruoli specifici (es. amministratore, moderatore, utente standard) I ruoli determinano i permessi per l'accesso alle risorse Facilita la gestione centralizzata dei permessi, ma può essere rigido in contesti dinamici

- per esempio per dare temporaneamente accesso a una singola risorsa a un solo utente

SLIDE ORIGINALE · diagrammi, tabelle e codice

Role-Based Access Control (RBAC)

Gli utenti sono assegnati a ruoli specifici (es. amministratore, moderatore, utente standard)
I ruoli determinano i permessi per l'accesso alle risorse
Facilita la gestione centralizzata dei permessi, ma può essere rigido in contesti dinamici
- per esempio per dare temporaneamente accesso a una singola risorsa a un solo utente



saiferlab.ai

11

08 / SLIDE 012 Attribute-Based Access Control (ABAC)

Lezione: Autenticazione e autorizzazione
Fonte: 08_autenticazione_autorizzazione.pdf, pagina 12 di 14

Spiegazione per studiare

ABAC decide in base a proprietà dell'utente e del contesto, come dipartimento, dispositivo e orario. Rispetto a ruoli fissi offre regole più flessibili, ma la logica di valutazione può risultare più difficile da progettare e controllare.

Definizioni, passaggi ed esempi presenti nella slide

I permessi dipendono da attributi dell'utente (es. età, dipartimento, orario di accesso) e del contesto (es. dispositivo usato, posizione geografica)

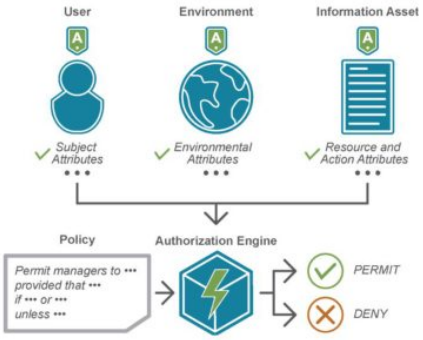
- Offre maggiore flessibilità rispetto a RBAC
- Può risultare più complesso da implementare e gestire

SLIDE ORIGINALE · diagrammi, tabelle e codice

Attribute-Based Access Control (ABAC)

I permessi dipendono da attributi dell'utente (es. età, dipartimento, orario di accesso) e del contesto (es. dispositivo usato, posizione geografica)

- Offre maggiore flessibilità rispetto a RBAC
- Può risultare più complesso da implementare e gestire



saiferlab.ai

12

08 / SLIDE 013 Access Control List (ACL)

Lezione: Autenticazione e autorizzazione

Fonte: 08_autenticazione_autorizzazione.pdf, pagina 13 di 14

Spiegazione per studiare

Con una ACL ciascuna risorsa mantiene una lista di identità o gruppi autorizzati e delle operazioni permesse. Il controllo è granulare, ma amministrare molte liste diventa complesso quando crescono risorse e utenti.

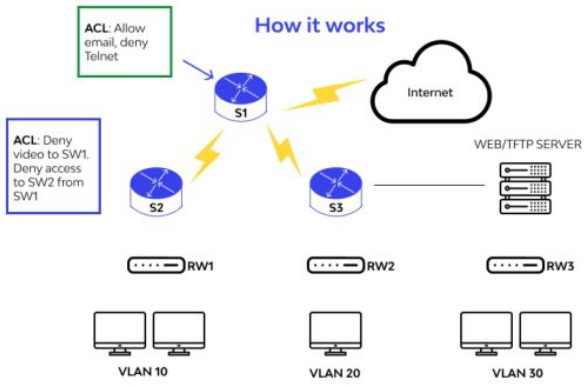
Definizioni, passaggi ed esempi presenti nella slide

Le risorse hanno liste di controllo accessi che specificano chi può accedere e con quali permessi Permette una gestione dettagliata dei permessi a livello di singola risorsa Può diventare difficile da amministrare in sistemi con molte risorse e utenti

SLIDE ORIGINALE · diagrammi, tabelle e codice

Access Control List (ACL)

Le risorse hanno liste di controllo accessi che specificano chi può accedere e con quali permessi
Permette una gestione dettagliata dei permessi a livello di singola risorsa
Può diventare difficile da amministrare in sistemi con molte risorse e utenti



saiferlab.ai

13

08 / SLIDE 014 Sicurezza e best practice per autenticazione e autorizzazione

Lezione: Autenticazione e autorizzazione
Fonte: 08_autenticazione_autorizzazione.pdf, pagina 14 di 14

Spiegazione per studiare

Le best practice affrontano protezione delle password, trasmissioni sicure, gestione dei token e controllo rigoroso dei permessi. La sicurezza va applicata sia durante l'accesso iniziale sia per ogni operazione successiva sulle risorse protette.

Definizioni, passaggi ed esempi presenti nella slide

- Protezione delle credenziali: utilizzo di hashing e salting per le password
- Uso di HTTPS per la protezione delle comunicazioni
- Limitazione della durata delle sessioni per ridurre i rischi di attacchi
- Logging e monitoraggio per rilevare accessi sospetti
- Principio del privilegio minimo: concedere solo i permessi strettamente necessari
- Revisione periodica dei permessi: evitare che utenti ex-dipendenti o con ruoli cambiati abbiano ancora accesso a dati sensibili
- Implementazione di audit trail: tracciare tutte le modifiche ai permessi e gli accessi effettuati

SLIDE ORIGINALE · diagrammi, tabelle e codice

